

Proyecto: Hardening de Servidor Linux

Iván Arana Hernández

Este proyecto documenta la transformación de una instalación básica de Linux en un servidor fortificado. El objetivo principal es aplicar los principios de defensa en profundidad mediante la auditoría del sistema operativo, el control del tráfico de red perimetral y la mitigación proactiva de ataques. A través de este laboratorio, se estudia la comprensión práctica sobre cómo evaluar la postura de seguridad inicial de un host, remediar vulnerabilidades de configuración nativas y garantizar un acceso remoto seguro bajo el principio de menor privilegio.

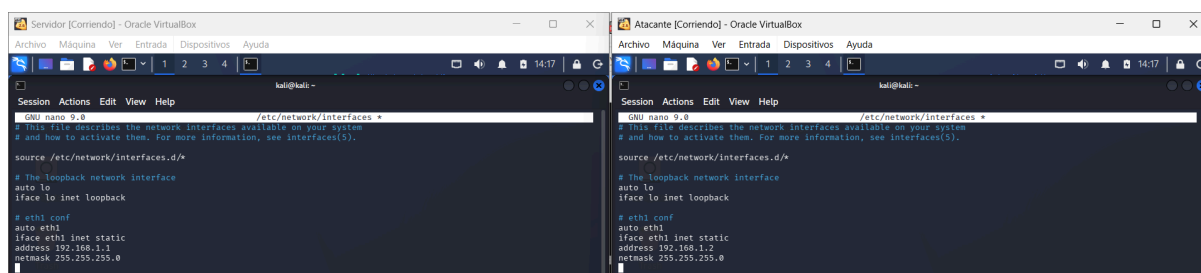
Herramientas Utilizadas:

- **Lynis:** Auditoría de seguridad y evaluación de cumplimiento del sistema operativo.
- **iptables:** Configuración directa de reglas de filtrado de paquetes a bajo nivel para gestionar el tráfico de red, establecer políticas de denegación por defecto y proteger la superficie de ataque perimetral.
- **OpenSSH:** Bastionado del acceso remoto mediante autenticación por clave pública y restricción de usuarios críticos.
- **Fail2ban:** Sistema de prevención de intrusos (IPS) que monitoriza logs y bloquea direcciones IP hostiles de forma automatizada.
- **Nmap:** Escaneo de puertos para validar la exposición de servicios antes y después del bastionado.
- **Hydra:** Simulación de ataques de fuerza bruta para verificar las políticas de bloqueo en tiempo real.
- **VirtualBox:** Creación del laboratorio aislado con redes NAT para la interacción segura entre la máquina atacante y el servidor.

Contexto inicial

El escenario de partida de este proyecto consta de una infraestructura virtualizada compuesta por dos máquinas (Servidor y Atacante) conectadas en una red local aislada. La máquina **Servidor** representa un host Linux recién desplegado, el cual tiene servicios críticos habilitados, como SSH, pero mantiene las configuraciones inseguras por defecto de fábrica. Al carecer de políticas de filtrado de red (firewall) y de mecanismos de defensa activa, se encuentra completamente expuesto a escaneos y accesos no autorizados. Por su parte, la máquina **Atacante** asume el rol de un actor malicioso o auditor externo, cuyo objetivo inicial es realizar tareas de reconocimiento y simular ataques de fuerza bruta para evidenciar la superficie de ataque antes de aplicar cualquier medida de bastionado.

Para aislar este entorno de pruebas, hemos configurado una red interna estática editando el archivo `/etc/network/interfaces` en ambos equipos. Como se muestra en la captura de pantalla, el Servidor se queda con la IP 192.168.1.1 y la máquina Atacante con la 192.168.1.2, creando un canal privado y directo para lanzar los escaneos.

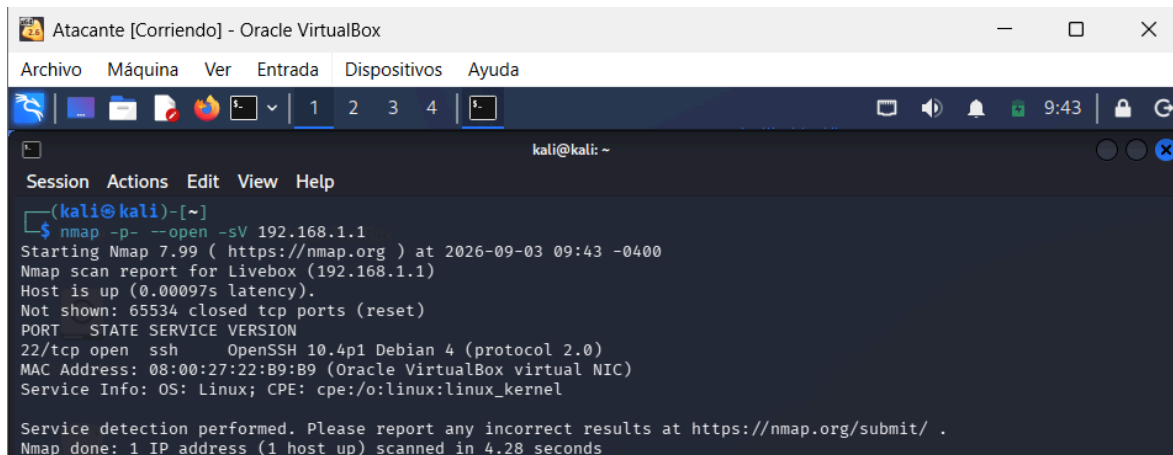


Para simular un escenario de trabajo realista, el Servidor tiene habilitado el servicio OpenSSH con su configuración de fábrica y cuenta con un usuario básico de pruebas (sysadmin). Esto nos proporciona un punto de entrada activo y vulnerable que usaremos como objetivo principal para lanzar los ataques de fuerza bruta y aplicar el bastionado posterior.

Fase 1: Reconocimiento y Auditoría

Para evaluar la postura de seguridad inicial del servidor, se realizaron dos pruebas independientes: un escaneo perimetral externo y una auditoría interna del sistema operativo.

Escaneo de Puertos: Desde la máquina Atacante, se ejecutó un escaneo de puertos completos con Nmap para identificar los puertos abiertos.

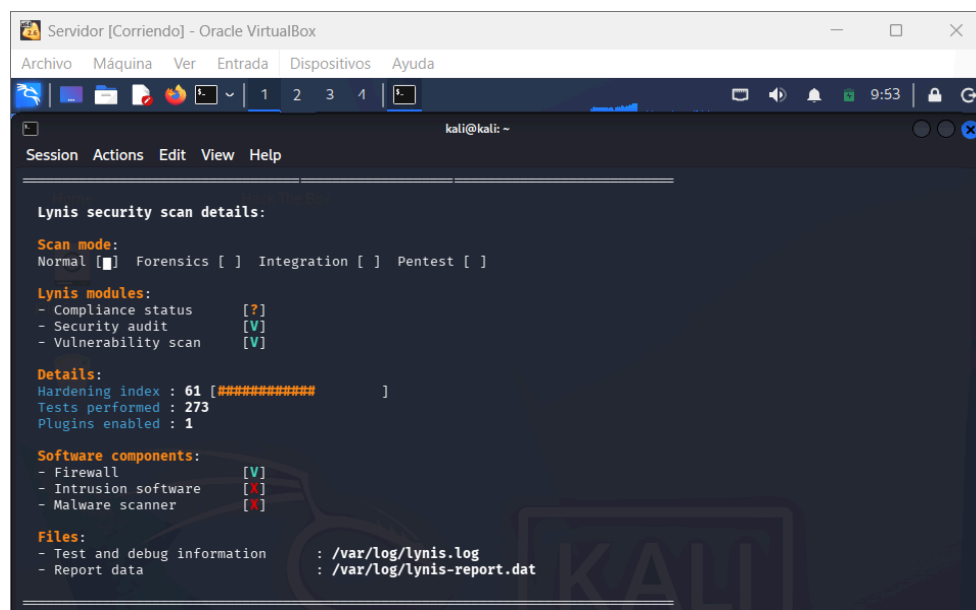


```
(kali@kali)-[~]
$ nmap -p- --open -sV 192.168.1.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 09:43 -0400
Nmap scan report for Livebox (192.168.1.1)
Host is up (0.00097s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.4p1 Debian 4 (protocol 2.0)
MAC Address: 08:00:27:22:B9:B9 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 4.28 seconds
```

Como se observa en la evidencia, el puerto 22 (SSH) se encuentra abierto y respondiendo a peticiones sin ningún tipo de restricción o filtrado perimetral.

Auditoría del Sistema: En la máquina Servidor, se ejecutó la herramienta Lynis para analizar las configuraciones nativas del sistema operativo, el kernel y las políticas de acceso por defecto. Comando: sudo lynis audit system



```
Lynis security scan details:

Scan mode:
Normal [X] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Details:
Hardening index : 61 [#####]
Tests performed : 273
Plugins enabled : 1

Software components:
- Firewall [V]
- Intrusion software [X]
- Malware scanner [X]

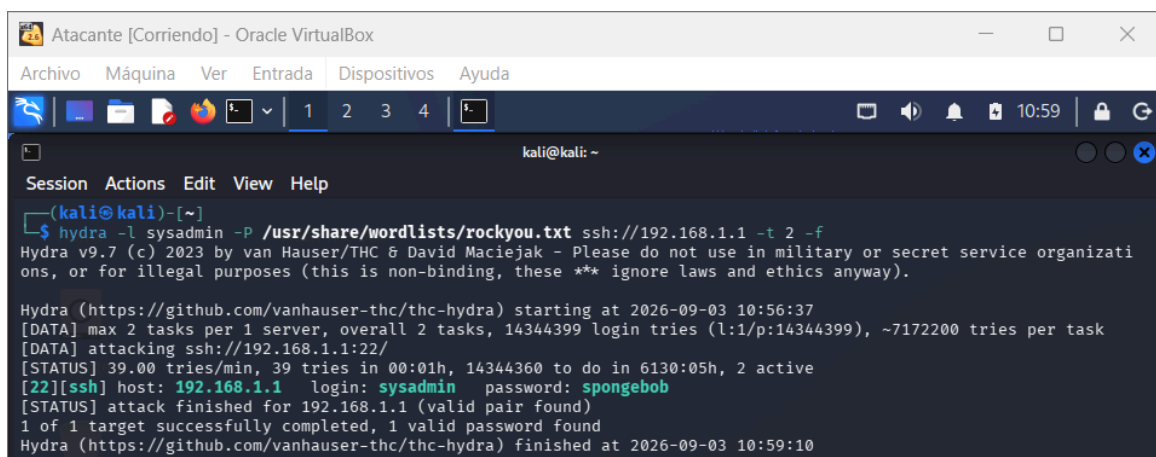
Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat
```

El análisis inicial arroja un Índice de Bastionado de 61. Aunque el escáner detecta la presencia del componente de firewall nativo (iptables), este carece de reglas de bloqueo activo. Asimismo, evidencia la ausencia total de software de prevención de intrusiones (Intrusion software: [X]), lo que deja al puerto SSH expuesto a ataques de diccionario. Esta puntuación de 61 establece la métrica base que se pretende superar.

Fase 2: Simulación de Ataque Ofensivo

Para demostrar la vulnerabilidad del servicio SSH frente a ataques de fuerza bruta, se ejecutó una ofensiva controlada desde la máquina Atacante utilizando Hydra y el diccionario estándar rockyou.txt.

Ejecución del Ataque: Se lanzó la herramienta Hydra contra el usuario objetivo sysadmin. En la formulación del comando, se aplicó el parámetro -t 2 para limitar el ataque a dos hilos concurrentes; esto evita saturar el límite de conexiones no autenticadas del demonio SSH (MaxStartups) y previene que el servidor aborte el escaneo. Asimismo, se integró el parámetro -f para forzar la detención inmediata de la herramienta en el momento exacto en que hallara una credencial válida, optimizando el tiempo de la prueba.

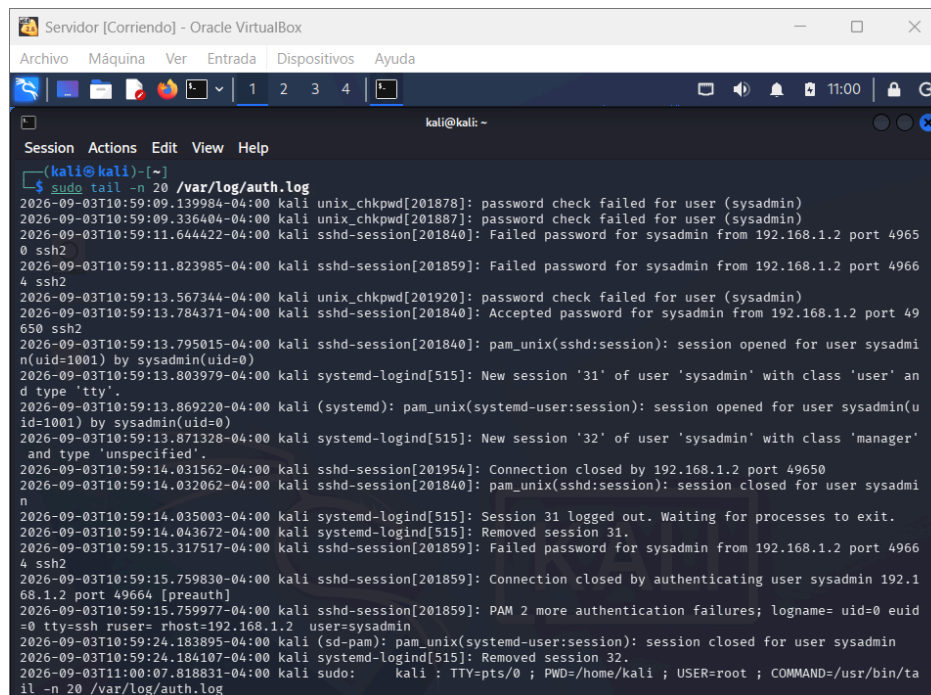


```
Atacante [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
kali@kali: ~
$ hydra -l sysadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.1 -t 2 -f
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-03 10:56:37
[DATA] max 2 tasks per 1 server, overall 2 tasks, 14344399 login tries (l:1/p:14344399), ~7172200 tries per task
[DATA] attacking ssh://192.168.1.1:22/
[STATUS] 39.00 tries/min, 39 tries in 00:01h, 14344360 to do in 6130:05h, 2 active
[22][ssh] host: 192.168.1.1 login: sysadmin password: spongebob
[STATUS] attack finished for 192.168.1.1 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-03 10:59:10
```

La herramienta logró comprometer la cuenta exitosamente, revelando la contraseña en texto plano (spongebob) y evidenciando que las protecciones nativas son insuficientes.

Registro de Evidencias: Para auditar el impacto a nivel de sistema y justificar futuras medidas de mitigación, se inspeccionaron los registros de autenticación en la máquina Servidor.



```
Serveridor [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
kali@kali ~
Session Actions Edit View Help
(kali@kali)~$ sudo tail -n 20 /var/log/auth.log
2026-09-03T10:59:09.139984-04:00 kali unix_chkpwd[201878]: password check failed for user (sysadmin)
2026-09-03T10:59:09.336404-04:00 kali unix_chkpwd[201887]: password check failed for user (sysadmin)
2026-09-03T10:59:11.644422-04:00 kali sshd-session[201840]: Failed password for sysadmin from 192.168.1.2 port 4965
0 ssh2
2026-09-03T10:59:11.823985-04:00 kali sshd-session[201859]: Failed password for sysadmin from 192.168.1.2 port 4966
4 ssh2
2026-09-03T10:59:13.567344-04:00 kali unix_chkpwd[201920]: password check failed for user (sysadmin)
2026-09-03T10:59:13.784371-04:00 kali sshd-session[201840]: Accepted password for sysadmin from 192.168.1.2 port 49
650 ssh2
2026-09-03T10:59:13.795015-04:00 kali sshd-session[201840]: pam_unix(sshd:session): session opened for user sysadmin
(uid=1001) by sysadmin(uid=0)
2026-09-03T10:59:13.803979-04:00 kali systemd-logind[515]: New session '31' of user 'sysadmin' with class 'user' an
d type 'tty'.
2026-09-03T10:59:13.869220-04:00 kali (systemd): pam_unix(systemd-user:session): session opened for user sysadmin(u
id=1001) by sysadmin(uid=0)
2026-09-03T10:59:13.871328-04:00 kali systemd-logind[515]: New session '32' of user 'sysadmin' with class 'manager'
and type 'unspecified'.
2026-09-03T10:59:14.031562-04:00 kali sshd-session[201954]: Connection closed by 192.168.1.2 port 49650
2026-09-03T10:59:14.032062-04:00 kali sshd-session[201840]: pam_unix(sshd:session): session closed for user sysadmin
2026-09-03T10:59:14.035003-04:00 kali systemd-logind[515]: Session 31 logged out. Waiting for processes to exit.
2026-09-03T10:59:14.043672-04:00 kali systemd-logind[515]: Removed session 31.
2026-09-03T10:59:15.317517-04:00 kali sshd-session[201859]: Failed password for sysadmin from 192.168.1.2 port 4966
4 ssh2
2026-09-03T10:59:15.759830-04:00 kali sshd-session[201859]: Connection closed by authenticating user sysadmin 192.1
68.1.2 port 49664 [preauth]
2026-09-03T10:59:15.759977-04:00 kali sshd-session[201859]: PAM 2 more authentication failures; logname= uid=0 euid
=0 tty=ssh ruser= rhost=192.168.1.2 user=sysadmin
2026-09-03T10:59:24.183895-04:00 kali (sd-pam): pam_unix(systemd-user:session): session closed for user sysadmin
2026-09-03T10:59:24.184107-04:00 kali systemd-logind[515]: Removed session 32.
2026-09-03T11:00:07.818831-04:00 kali sudo:    kali : TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/ta
il -n 20 /var/log/auth.log
```

El archivo de logs registra un patrón innegable de ataque de diccionario. Se observan múltiples eventos Failed password generados desde la IP atacante (192.168.1.2), culminando en un acceso no autorizado (Accepted password).

Fase 3: Bastionado Perimetral con iptables

Para mitigar la exposición de los servicios del sistema, se implementó una configuración de cortafuegos restrictiva basada en el principio de mínimo privilegio utilizando iptables.

Aislamiento del Entorno Base: Se estableció una política de "Denegación por Defecto" (Default Drop) en la cadena de entrada del kernel, autorizando exclusivamente el tráfico interno de loopback y las conexiones previamente establecidas para garantizar la estabilidad del sistema.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo iptables -P INPUT DROP  
(kali@kali)-[~]  
$ sudo iptables -A INPUT -i lo -j ACCEPT  
(kali@kali)-[~]  
$ sudo iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
```

Verificación del Bloqueo: Para validar la eficacia de las reglas, se intentó establecer comunicación desde la máquina Atacante mediante peticiones ICMP (ping) y conexiones SSH.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ping -c 3 192.168.1.1  
PING 192.168.1.1 (192.168.1.1) 56(84) bytes of data:  
  
— 192.168.1.1 ping statistics —  
3 packets transmitted, 0 received, 100% packet loss, time 2051ms  
  
(kali@kali)-[~]  
$ ssh sysadmin@192.168.1.1
```

Como se observa en la evidencia, el servidor rechaza silenciosamente las peticiones de red externas, aislando la máquina de escaneos y accesos no autorizados.

Excepción Controlada: En un entorno productivo ideal, el acceso remoto debe limitarse estrictamente a IPs confiables. En este escenario de auditoría, se configuró una regla específica para permitir el tráfico SSH entrante desde la máquina de pruebas.

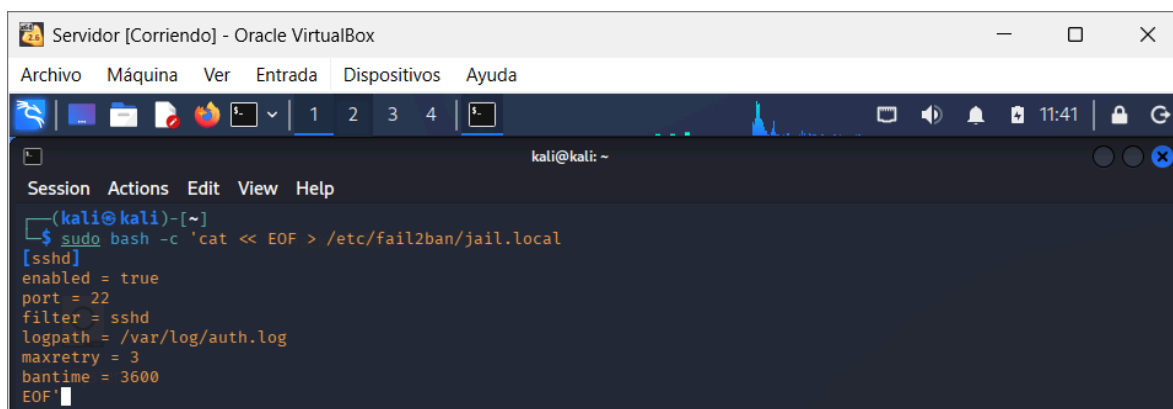
```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo iptables -P INPUT DROP  
(kali@kali)-[~]  
$ sudo iptables -A INPUT -i lo -j ACCEPT  
(kali@kali)-[~]  
$ sudo iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT  
(kali@kali)-[~]  
$ sudo iptables -A INPUT -i eth1 -p tcp -s 192.168.1.2 --dport 22 -j ACCEPT
```

Esta regla no solo restaura la capacidad de administración legítima, sino que expone controladamente el puerto 22. Esta decisión de diseño permite derivar la responsabilidad de la seguridad a la capa de aplicación, habilitando el despliegue de Fail2ban en la siguiente fase para analizar los logs de autenticación y bloquear dinámicamente futuros ataques de fuerza bruta.

Fase 4: Hardening del Servicio SSH y Defensa Activa

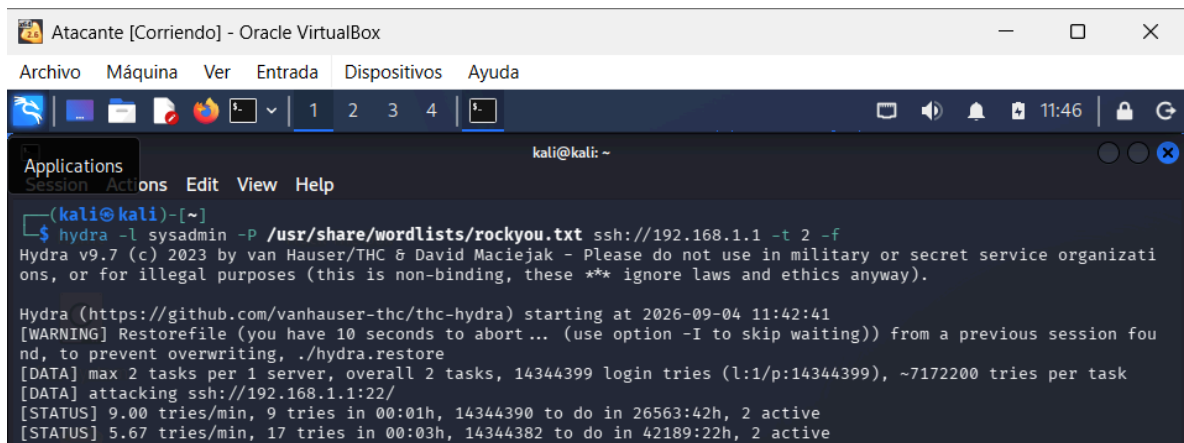
Para neutralizar los ataques de diccionario evidenciados en la Fase 2, se desplegó un sistema de prevención de intrusiones (Fail2ban) encargado de auditar los registros de autenticación y bloquear dinámicamente las IPs hostiles.

Implementación de Políticas de Bloqueo: Se configuró una regla de vigilancia personalizada (jail.local) para el demonio SSH. Esta directiva establece un umbral de tolerancia estricto de 3 intentos fallidos (maxretry = 3), tras los cuales se aplica una restricción de acceso a nivel de cortafuegos durante una hora (bantime = 3600).



```
Servidor [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ sudo bash -c 'cat << EOF > /etc/fail2ban/jail.local
[sshd]
enabled = true
port = 22
filter = sshd
logpath = /var/log/auth.log
maxretry = 3
bantime = 3600
EOF'
```

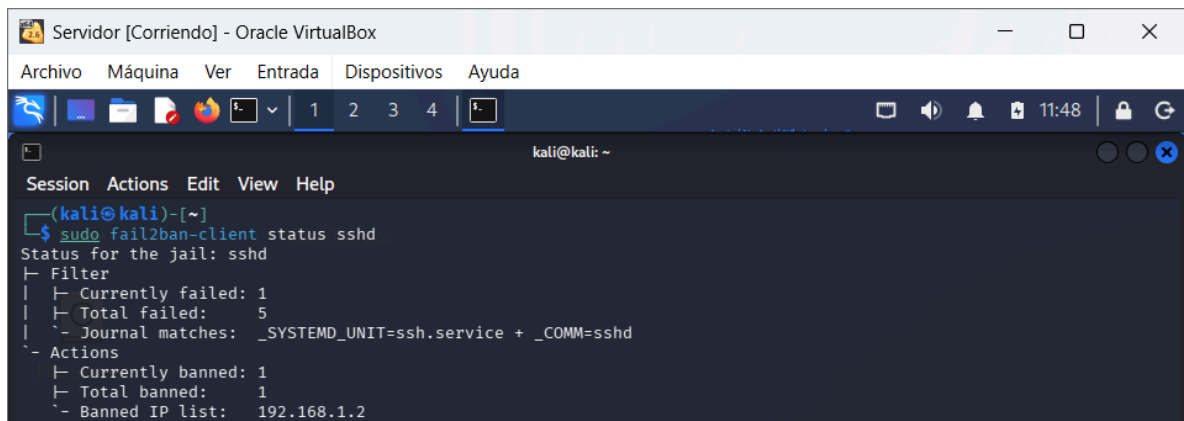
Simulación del Ataque y Respuesta del Sistema: Para validar la eficacia de la contramedida, se relanzó la ofensiva de fuerza bruta con Hydra. La herramienta sufrió una caída drástica de rendimiento en los primeros minutos de ejecución, procesando apenas 17 intentos antes de quedar suspendida. Este comportamiento confirma que el sistema de defensa reaccionó aislando la conexión y descartando los paquetes entrantes.



```
(kali@kali)-[~]
$ hydra -l sysadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.1 -t 2 -f
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-04 11:42:41
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 2 tasks per 1 server, overall 2 tasks, 14344399 login tries (l:1/p:14344399), ~7172200 tries per task
[DATA] attacking ssh://192.168.1.1:22/
[STATUS] 9.00 tries/min, 9 tries in 00:01h, 14344390 to do in 26563:42h, 2 active
[STATUS] 5.67 tries/min, 17 tries in 00:03h, 14344382 to do in 42189:22h, 2 active
```

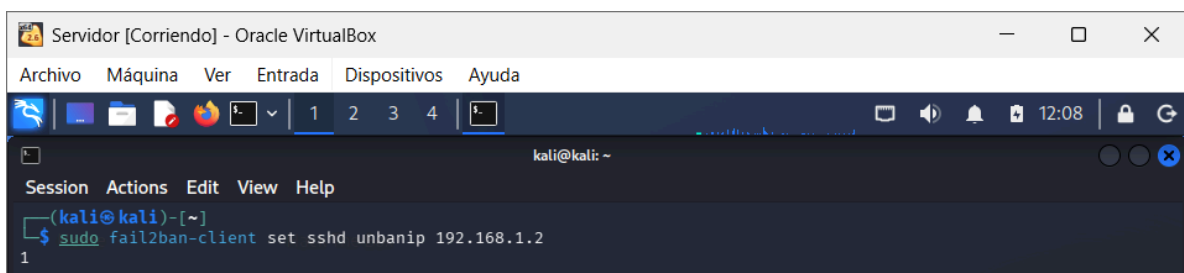
Evidencia de Mitigación: La consulta del estado del servicio en el Servidor corrobora la contención técnica del ataque. Fail2ban identificó la anomalía en los registros y añadió automáticamente la dirección IP ofensiva a la lista negra del cortafuegos.



```
(kali@kali)-[~]
$ sudo fail2ban-client status sshd
Status for the jail: sshd
- Filter
  | - Currently failed: 1
  | - Total failed: 5
  | - Journal matches: _SYSTEMD_UNIT=ssh.service + _COMM=sshd
- Actions
  | - Currently banned: 1
  | - Total banned: 1
  | - Banned IP list: 192.168.1.2
```

Además, para erradicar definitivamente el riesgo asociado a los ataques de diccionario, se sustituyó el método de autenticación basado en contraseñas por un sistema de criptografía asimétrica robusto.

Restablecimiento de Conexión: Previo a la configuración de las claves, se levantó la restricción temporal impuesta por Fail2ban a la dirección IP de administración (192.168.1.2), restaurando el flujo de red legítimo.



```
(kali@kali)-[~]
$ sudo fail2ban-client set sshd unbanip 192.168.1.2
1
```


Generación e Intercambio de Claves Criptográficas: Desde la máquina Atacante, se generó un par de claves RSA de 4096 bits. La clave pública resultante se inyectó en el archivo de claves autorizadas del Servidor, vinculando el acceso administrativo a un token criptográfico en lugar de a una credencial estática.

```
Atacante [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

kali@kali: ~
Session Actions Edit View Help

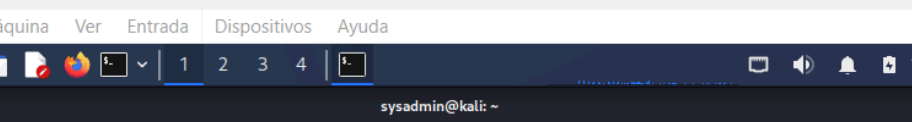
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ ssh-keygen -t rsa -b 4096
Generating public/private rsa key pair.
Enter file in which to save the key (/home/kali/.ssh/id_rsa):
Enter passphrase for "/home/kali/.ssh/id_rsa" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/.ssh/id_rsa
Your public key has been saved in /home/kali/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:1NnB5Dk07//pzMTziq+Hv67h4E30Vaocyybyub0tNxM kali@kali
The key's randomart image is:
+--[RSA 4096]--+
|
| . o =
| . o = .
| . o = .
| . o = .
| S o o .
| +E=.o
| . o Oo.+
| +.X=o=
| B+BXBBol
+--[SHA256]--+

(kali@kali)-[~]
$ ssh-copy-id sysadmin@192.168.1.1
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/home/kali/.ssh/id_rsa.pub"
The authenticity of host '192.168.1.1 (192.168.1.1)' can't be established.
ED25519 key fingerprint is: SHA256:9cr++6VDP7Uo/tsTrngp0aAGx8dDRPatk2UMwk0y49o
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to install the new key
s
sysadmin@192.168.1.1's password:

Number of key(s) added: 1

Now try logging into the machine, with: "ssh 'sysadmin@192.168.1.1'"
and check to make sure that only the key(s) you wanted were added.
```

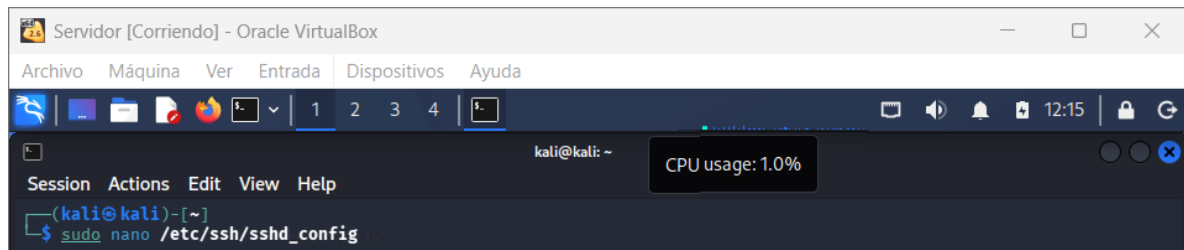
Verificación del Mecanismo de Autenticación: Se validó la correcta implementación del sistema estableciendo una nueva sesión SSH. El servidor concedió acceso inmediato al reconocer la firma de la clave privada, omitiendo por completo el prompt de contraseña.



The screenshot shows a Kali Linux terminal window. The title bar reads "Atacante [Corriendo] - Oracle VirtualBox". The terminal interface includes a menu bar with "Archivo", "Máquina", "Ver", "Entrada", "Dispositivos", and "Ayuda". Below the menu bar is a toolbar with various icons. The terminal content shows a user logging in as "sysadmin" on a "kali" machine. The prompt is "(sysadmin@kali)-[~]". The user has entered a command, and the terminal shows the output of the command.

```
(kali@kali)-[~]  
$ ssh sysadmin@192.168.1.1  
Linux kali 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64  
  
The programs included with the Kali GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
(sysadmin@kali)-[~]  
$
```

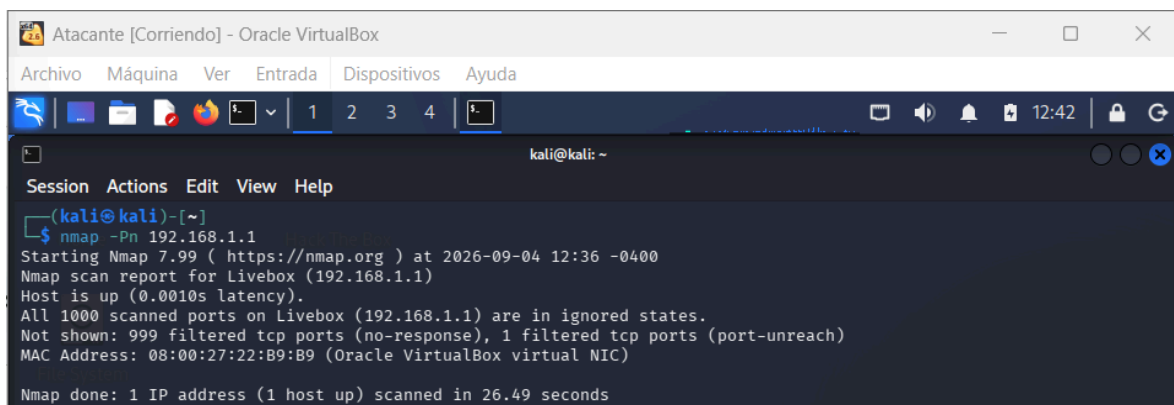
Bastionado Final del Demonio SSH: Como contramedida definitiva, se editó el archivo de configuración principal de OpenSSH (sshd_config) para aplicar la directiva PasswordAuthentication no. Esta modificación estructural cierra el vector de ataque original: cualquier intento de autenticación interactiva o fuerza bruta será rechazado por el propio servicio antes de ser procesado, haciendo inútiles herramientas como Hydra.



Fase 5: Validación y Auditoría Final

Para verificar la eficacia de las contramedidas implementadas, se realizó una re-evaluación del sistema combinando escaneos de red externos y auditoría de configuración interna.

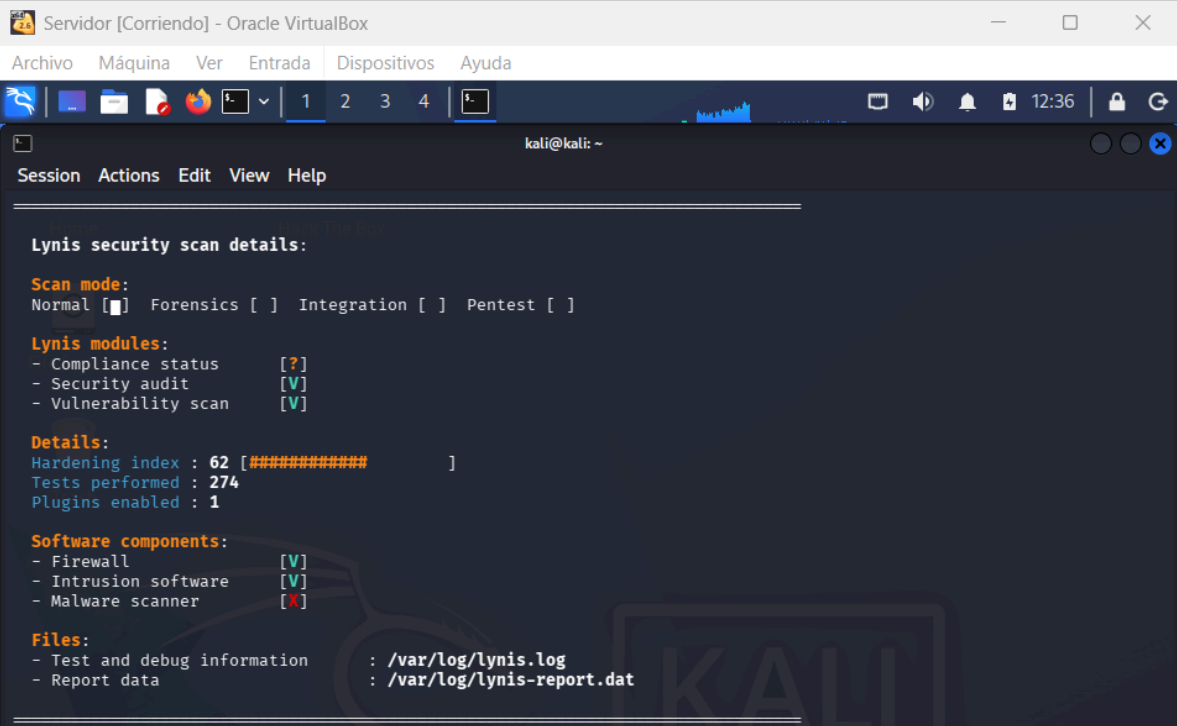
Auditoría de Superficie de Red: Se ejecutó un escaneo de puertos desde la máquina atacante para comprobar la robustez perimetral. Para este escaneo fue estrictamente necesario añadir el parámetro -Pn. Este flag instruye a Nmap para que omita la fase inicial de descubrimiento de host (ping ICMP) y asuma que el objetivo está encendido. Sin este parámetro, Nmap creería que el servidor está apagado, ya que nuestra política de cortafuegos ahora bloquea y descarta silenciosamente los pings.



Como evidencia la salida del comando, la totalidad de los 1000 puertos escaneados se encuentran aislados ("ignored states"). Destaca que 999 puertos aparecen filtrados sin respuesta (no-response), lo que demuestra empíricamente el éxito de la

política de "Denegación por Defecto" (DROP) de iptables: el servidor absorbe y destruye los paquetes del escáner sin devolver información al atacante, volviendo la infraestructura opaca a rastreos externos. Por su parte, el puerto restante se reporta como filtrado inalcanzable (port-unreach), confirmando que también permanece completamente bloqueado e inaccesible, emitiendo únicamente un rechazo estándar a nivel de red.

Auditoría de Cumplimiento Específico: Los resultados comparativos del escáner Lynis muestran que el sistema ha detectado e integrado correctamente el software de prevención de intrusiones (Fail2ban), cambiando el estado del componente Intrusion software de vulnerable a validado.



```
Servidor [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
kali@kali: ~
Session  Actions  Edit  View  Help

Lynis security scan details:

Scan mode:
Normal [X] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status      [?]
- Security audit         [V]
- Vulnerability scan     [V]

Details:
Hardening index : 62 [#####]
Tests performed : 274
Plugins enabled  : 1

Software components:
- Firewall               [V]
- Intrusion software     [V]
- Malware scanner        [X]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat
```

Análisis del Índice de Bastionado: El Hardening index global experimentó un incremento conservador (de 61 a 62). Esto demuestra que las acciones correctivas aplicadas fueron intervenciones técnicas altamente focalizadas sobre el servicio SSH y el perímetro de red. Se priorizó neutralizar el vector de ataque principal de forma selectiva, evitando alterar configuraciones globales del kernel o del sistema de archivos que pudieran comprometer la estabilidad del entorno de producción.

Conclusiones y Aprendizaje

Como estudiante, este proyecto inicial me ha servido como una toma de contacto muy práctica con la ciberseguridad y la administración de sistemas en Linux. Al alternar entre el rol de atacante y el de defensor, he podido entender de primera mano por qué se aplican estas configuraciones en un entorno real. El procedimiento comenzó utilizando herramientas como Lynis y Nmap para auditar y conocer el nivel de exposición del servidor. Después, al usar Hydra para lanzar un ataque de fuerza bruta, comprobé directamente la debilidad de depender únicamente de contraseñas. En la parte defensiva, configurar el cortafuegos con iptables me ayudó a asimilar el concepto de denegar todo el tráfico por defecto. Finalmente, la integración de Fail2ban y el cambio a claves criptográficas en SSH me demostraron cómo automatizar la defensa ante intrusiones y asegurar el acceso de forma mucho más robusta.

Al ser un laboratorio inicial, esta infraestructura deja la puerta abierta a varias mejoras interesantes para seguir practicando. Un siguiente paso lógico sería implementar un doble factor de autenticación (MFA) para el acceso por SSH, pidiendo un código temporal desde el móvil además de la clave. También se podría instalar un sistema de monitorización como Wazuh o el stack ELK, para dejar de leer logs en texto plano y ver los eventos de seguridad en un panel gráfico. Además, este entorno es ideal para empezar a probar herramientas de automatización como Ansible o para desplegar un servidor web básico y practicar cómo protegerlo frente a otro tipo de ataques.